

March 22, 2019

# Teaching 'Shift Left on Security'

**Chris Swan (@cpswan)**  
**Fellow, VP, CTO Global Delivery**

# Chris Swan – Why Me?

@cpswan



Combat Systems Engineer - Royal Navy  
Security R&D - Credit Suisse  
CTO Security - UBS



CTO - Cohesive Networks  
CTO Global Infrastructure Services - CSC  
CTO Global Delivery - DXC Technology



# DXC Technology at a glance

**DXC**  
LISTED  
NYSE

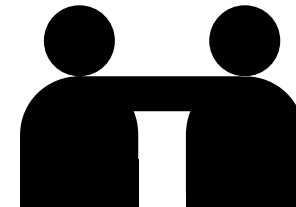
**\$21+B**

global IT services leader



**250+**

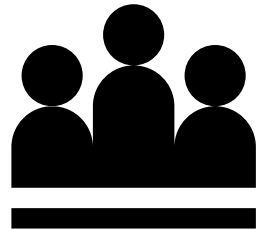
partner network with  
best-of-breed partners  
16 strategic partners



**~6,000**

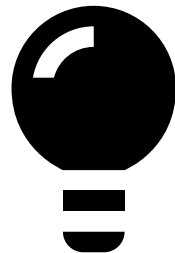
clients

200+ Fortune 500 companies



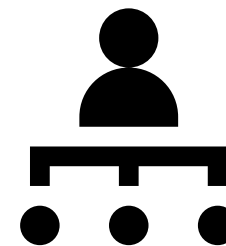
**60+**

years of innovation



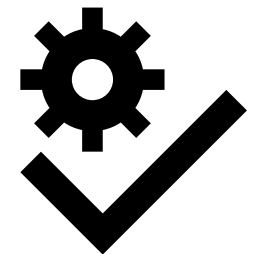
**~130,000**

employees worldwide



**9**

streamlined offering  
families



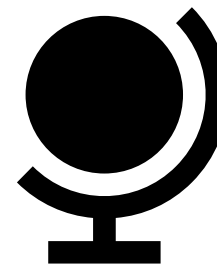
**#19**

of *CR Magazine's* 100  
Best Corporate Citizens  
for 2018



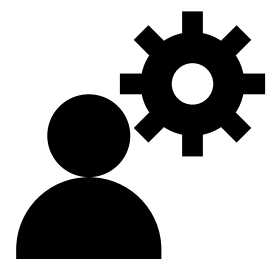
**70+**

countries



**10,000+**

Agile/DevOps  
professionals



# DevOps Dojo by the numbers so far



14,000+



650+



2700+

# Stripe 1 Modules



# Story / Character based

Adam (Admin / Site Reliability Engineer)



Santhosh (Scrum Master)



Tina (Tester)



Paulo (Product Owner)



Hal (Hacker)



Brenda (Business)



Selma (Security)

Selma is from Security.



Chun (Coach)



Dan (Developer)



Charlie (CEO)



# Welcome

Welcome to the **Yellow Belt DevOps Dojo** module on shifting security left.

## Purpose

The primary objective of the "Shift Left on Security" module is to help you to understand the principles and benefits of Shifting Left on Security. This is to enable you and your team to Shift Left on Security in your daily work.

The secondary objective is to give you an opportunity to complete a Shift Left on Security real world scenario using Katacoda in **your** Sandbox environment.

Remember the Sandbox is your personal clone of the Pet Clinic Repository. The Sandbox is the one which you created in the Welcome module. You are free to experiment in your Sandbox without fear of impacting the lab or other learners.

If you have not completed the Welcome module you should do so before continuing with the Shift Left On Security module.

By the end of the lesson, you should be able to

- Articulate the need to Shift Left on Security
- Integrate Security Testing in the daily work of the scrum team as part of a CI/CD pipeline
- Describe how to reduce surface areas of risk and enforce consistency in the the application of security testing.
- Understand the need to provide traceability of production artifacts
- Explain the importance of using commercially available and/or open source tools which the security team have reviewed and tools rather than custom solutions for security testing.

START SCENARIO

# Setting the scene



# Startup

DXC DevOps Dojo - Shift Left on Security

Lab

Get help ? FAQ

Shift Left on Security

◀ Step 2 of 8 ▶

To proceed with this lab you need to have your own copy of the Pet Clinic GitHub repository under your GitHub user name. If you have not done so please take the Welcome module.

Then run the following command to bring up Jenkins and connect it to your copy of the Pet Clinic application's code. This script may take a few minutes to run.

**Note:** you will re-use GitHub's "Personal Access Token" you have created in the Welcome module. If you need to generate a new one, go to <https://github.dxc.com/settings/tokens> and save it for later.

Let's go ahead and prepare our environment, click this:

`./prepare.sh` ✓

...answer the questions and wait for the "Click on 'CONTINUE'" message.

CONTINUE

Terminal

Jenkins

GitHub

Pet Clinic

+

```
"content_type": "json",
"url": "https://2886795268-8080-kitek04.environments.katacoda.com/github-webhook/",
"insecure_ssl": "0"
},
"updated_at": "2019-03-20T09:46:40Z",
"created_at": "2019-03-20T09:46:40Z",
"url": "https://github.dxc.com/api/v3/repos/chrissswan/pet-clinic/hooks/68345",
"test_url": "https://github.dxc.com/api/v3/repos/chrissswan/pet-clinic/hooks/68345/test",
"ping_url": "https://github.dxc.com/api/v3/repos/chrissswan/pet-clinic/hooks/68345/pings",
"last_response": {
  "code": null,
  "status": "unused",
  "message": null
}
}
}
Preparing tab to link to github.dxc.com...

7c51abe0329cf045778d937f5f6949c7e394283e3f3072cb4fc474fcf2f2dade
Waiting for Jenkins to come up...

Retry 1...
Retry 2...
Retry 3...
Retry 4...

```

Powered by  Katacoda

# Jenkins

DXC DevOps Dojo - Shift Left on Security

Lab

Get help ? FAQ

Shift Left on Security

◀ Step 3 of 8 ▶

Setup (continued)

- Now that Jenkins is ready, open the Jenkins admin dashboard: <https://2886795268-8080-kitek04.environments.katacoda.com/>
- Authenticate with the user `admin`, password `7b6471`

**TIP:** Firefox user? Use `CTRL + INS` / `SHIFT + INS` to copy/paste your Personal Access Token in the window.

CONTINUE

Jenkins

search admin | log out

Jenkins

New Item

People

Build History

Manage Jenkins

My Views

Open Blue Ocean

Credentials

New View

Build Queue

No builds in the queue.

add description

All +

| S | W | Name ↓                     | Last Success | Last Failure | Last Duration | Fav | Robot Results |
|---|---|----------------------------|--------------|--------------|---------------|-----|---------------|
|   |   | <a href="#">pet-clinic</a> | N/A          | N/A          | N/A           |     |               |

Powered by Katacoda

# A week has passed...

DXC DevOps Dojo - Shift Left on Security

Lab

Get help ? FAQ

Shift Left on Security

Step 4 of 8

S



I know OWASP (Open Web Application Security Project)! This is a not-for-profit charitable organization, and it can be trusted. Including this dependency checker in the pipeline is a great idea! I will sleep better at night 🛡️🌙 knowing that we are reducing our attack surface on that front by including security in our CI pipeline, in other words by shifting security left towards the original cause of the vulnerability.

CONTINUE

TerminalJenkinsGitHubPet Clinic+

Jenkins

searchadmin | log out

ENABLE AUTO REFRESH

New Item

People

Build History

Manage Jenkins

My Views

Open Blue Ocean

Credentials

New View

Build Queue

No builds in the queue.

All+

| S                                                                                     | W                                                                                     | Name ↓                     | Last Success | Last Failure | Last Duration | Fav | Robot Results |
|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|----------------------------|--------------|--------------|---------------|-----|---------------|
|  |  | <a href="#">pet-clinic</a> | N/A          | N/A          | N/A           |     |               |

add description

Powered by  KataCoda

# Adding OWASP dependency checker

 DXC DevOps Dojo - Shift Left on Security

Lab

Get help ? FAQ

Shift Left on Security

Terminal Jenkins GitHub Pet Clinic

Step 5 of 8

## Adding a dependency scanner



As Pet Clinic is a Java project, we can easily add the OWASP dependency check as part of our pipeline, in our `pom.xml` file, as a Maven plugin. Let's do this!

### Steps

- Navigate to your GitHub copy of the pet clinic application to find `pom.xml`
- Click on the pencil icon in the top right corner to edit the file
- Add the OWASP dependency checker as one of the plugins, around line 207 (after `</plugin>`):

## pom.xml file

### pom.xml file in master branch

[github.dxc.com/chrissswan/pet-clinic/blob/master/pom.xml](https://github.dxc.com/chrissswan/pet-clinic/blob/master/pom.xml)

### pom.xml file in deps-check branch

[github.dxc.com/chrissswan/pet-clinic/blob/deps-check/pom.xml](https://github.dxc.com/chrissswan/pet-clinic/blob/deps-check/pom.xml)

## Jenkinsfile

### Jenkinsfile file

[github.dxc.com/chrissswan/pet-clinic/blob/deps-check/Jenkinsfile](https://github.dxc.com/chrissswan/pet-clinic/blob/deps-check/Jenkinsfile)

Powered by  Katacoda

# Add the scanner to the pipeline

DXC DevOps Dojo - Shift Left on Security

Lab

Get help ? FAQ

Shift Left on Security

Step 6 of 8

## Add scanner in the pipeline



Now, we need to update the `Jenkinsfile` which describes our Continuous Integration pipeline to add the dependency vulnerability scanner. Initially, I don't want to fail the build because of vulnerabilities in our dependencies. We want to stop the leak and be informed instead. I will mark the build as "unstable" if we have a vulnerability. Also, I am gathering a report for the vulnerabilities so that we can analyze it

### Steps

- Navigate to your copy of the pet clinic application

Jenkins pet-clinic

Pipeline Syntax

Credentials

Build Queue

No builds in the queue.

Build Executor Status

1 Idle

pet-clinic

Branches (1) Pull Requests (1)

| S                                                                                     | W                                                                                     | Name ↓                     | Last Success                      | Last Failure | Last Duration | Fav                                                                                                                                                                         | Robot Results |
|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|----------------------------|-----------------------------------|--------------|---------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------|
|  |  | <a href="#">deps-check</a> | 2 min 21 sec - <a href="#">#1</a> | N/A          | 1 min 8 sec   |   |               |

Icon: [S](#) [M](#) [L](#)

[Legend](#)  [RSS for all](#)  [RSS for failures](#)  [RSS for just latest builds](#)

Powered by  Katacoda

Page generated: Mar 20, 2019 9:57:31 AM UTC

# The broken build :/

DXC DevOps Dojo - Shift Left on Security

Lab

Get help ? FAQ

Shift Left on Security

Step 6 of 8

Build Now

View Configuration

Full Stage View

OWASP Dependency Check Report

jacoco report

Open Blue Ocean

Pipeline Syntax

pet-clinic < 9

Pipeline

Changes

Tests

Artifacts

Refresh

Settings

Logout

Pull Request: PR-10

Q: 3%

Changes by devcloud: support

Commit: 71b6c94

9 minutes ago

Pull request #10 updated

NAME

SIZE

pipeline.log

-

OWASP Dependency Check Report

-

CONTINUE

Terminal

Jenkins

GitHub

Pet Clinic

+

Back to PR-2

dependency-check-report

Zip

- Dependencies Scanned: 87 (57 unique)
- Vulnerable Dependencies: 3
- Vulnerabilities Found: 23
- Vulnerabilities Suppressed: 0
- ...

Display: [Showing Vulnerable Dependencies \(click to show all\)](#)

| Dependency                                                  | CPE                                                                                                                                                                                                                                                                  | Coordinates                                                      | Highest Severity | CVE Count | CPE Confidence | Evidence Count |
|-------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------|------------------|-----------|----------------|----------------|
| <a href="#">spring-boot-starter-cache-1.4.7.RELEASE.jar</a> | <a href="#">cpe:/a:pivotal_software:spring_boot:1.4.7</a>                                                                                                                                                                                                            | org.springframework.boot:spring-boot-starter-cache:1.4.7.RELEASE | High             | 2         | Highest        | 29             |
| <a href="#">dom4j-1.6.1.jar</a>                             | <a href="#">cpe:/a:dom4j_project:dom4j:1.6.1</a>                                                                                                                                                                                                                     | dom4j:dom4j:1.6.1                                                | Medium           | 1         | Highest        | 25             |
| <a href="#">mysql-connector-java-5.1.47.jar</a>             | <a href="#">cpe:/a:oracle:mysql_connector/j:5.1.47</a><br><a href="#">cpe:/a:oracle:mysql:5.1.47</a><br><a href="#">cpe:/a:oracle:mysql_connectors:5.1.47</a><br><a href="#">cpe:/a:mysql:mysql:5.1.47</a><br><a href="#">cpe:/a:oracle:mysql_connector/j:5.1.47</a> | mysql:mysql-connector-java:5.1.47                                | Medium           | 20        | Highest        | 33             |

Dependencies

spring-boot-starter-cache-1.4.7.RELEASE.jar

Description:  
Starter for using Spring Framework's caching support

File Path: /root/.m2/repository/org/springframework/boot/spring-boot-starter-cache/1.4.7.RELEASE/spring-boot-starter-cache-1.4.7.RELEASE.jar

MD5: 21cd09c55a5adb3a24da8097fe326f73

© 2018 DXC Technology Company. All rights reserved.

Powered by

 Katacoda

# Removing stale dependencies

DXC DevOps Dojo - Shift Left on Security

Lab

Get help ? FAQ

Shift Left on Security

Terminal Jenkins GitHub Pet Clinic

◀ Step 7 of 8 ▶

The `spring-boot-starter-cache-1.4.7` dependency is in the `pom.xml` file. I remember we had to "pin" (stick to) this version previously, but we fixed the issue some time back. Let's update to the latest version.

### Steps

- Navigate to your copy of the pet clinic application to find `pom.xml`, in the same `deps-check` branch from the pull request
- Click on the pencil icon in the top right corner to edit the file
- Locate the `spring-boot-starter-cache` dependency, and remove the line with `<version>`
- Commit the change in this `deps-check` branch, in the context of the pull request
- The build will trigger automatically
- Navigate to [Jenkins](#) to see the results of the build
- This time, the OWASP check should come out with no error: everything good! ✓

## pom.xml file

### pom.xml file in master branch

[github.dxc.com/chrissswan/pet-clinic/blob/master/pom.xml](https://github.dxc.com/chrissswan/pet-clinic/blob/master/pom.xml)

### pom.xml file in deps-check branch

[github.dxc.com/chrissswan/pet-clinic/blob/deps-check/pom.xml](https://github.dxc.com/chrissswan/pet-clinic/blob/deps-check/pom.xml)

## Jenkinsfile

### Jenkinsfile file

[github.dxc.com/chrissswan/pet-clinic/blob/deps-check/Jenkinsfile](https://github.dxc.com/chrissswan/pet-clinic/blob/deps-check/Jenkinsfile)

Powered by  KataCoda

# The ground moves beneath our feet

DXC DevOps Dojo - Shift Left on Security

Lab

Get help ? FAQ

Shift Left on Security

Terminal Jenkins GitHub Pet Clinic

Step 7 of 8

The pipeline still fails?

S



As Hal said, new vulnerabilities are found all the time. It can be that a new vulnerability has been found since we last updated the Pet Clinic application. It may be difficult to find which dependency to update in the `pom.xml` file if it is a dependency of a dependency that is vulnerable.

At this point you have resolved the vulnerability we wanted you to resolve. If there are additional vulnerabilities identified you either fix them using the process which follows or you can ignore any additional items and proceed with the rest of the module.

You will need to walk the dependency tree. Let's first go to the correct branch in the repository:

pom.xml file

pom.xml file in master branch

[github.dxc.com/chrisswan/pet-clinic/blob/master/pom.xml](https://github.dxc.com/chrisswan/pet-clinic/blob/master/pom.xml)

pom.xml file in deps-check branch

[github.dxc.com/chrisswan/pet-clinic/blob/deps-check/pom.xml](https://github.dxc.com/chrisswan/pet-clinic/blob/deps-check/pom.xml)

Jenkinsfile

Jenkinsfile file

[github.dxc.com/chrisswan/pet-clinic/blob/deps-check/Jenkinsfile](https://github.dxc.com/chrisswan/pet-clinic/blob/deps-check/Jenkinsfile)

Powered by  Katacoda

DXC.technology

© 2018 DXC Technology Company. All rights reserved.

March 22, 2019 16

# It worked that time

DXC DevOps Dojo - Shift Left on Security

Lab

Get help ? FAQ

Shift Left on Security

◀ Step 8 of 8 ▶

Continuous checking

H

Dang! You make my job really hard now! That's OK though, I continuously monitor for new vulnerabilities. This is a waiting game at this point.

S

Now that we have our dependency scanner in place, how can we continuously scan for new vulnerabilities to defeat the hackers?

TerminalJenkinsGitHubPet Clinic+

Jenkins pet-clinic PR-2

ENABLE AUTO REFRESH

Full Stage View

OWASP Dependency Check Report

jacoco report

Open Blue Ocean

Pipeline Syntax

Build History

trend

find

#3

Mar 20, 2019 10:06 AM

#2

Mar 20, 2019 10:00 AM

#1

Mar 20, 2019 9:55 AM

RSS for all

RSS for failures

Pull Request PR-2

Full project name: pet-clinic/PR-2

Recent Changes

Test Result Trend

40

Powered by KataCoda

# Setting up daily scans

DXC DevOps Dojo - Shift Left on Security

Lab

Get help ? FAQ

Shift Left on Security

Terminal Jenkins GitHub Pet Clinic

Step 8 of 8

Steps

- Navigate to your copy of the pet clinic application to find `Jenkinsfile`, in the same `deps-check` branch from the pull request
- Click on the pencil icon in the top right corner to edit the file
- Below `agent any` in the `Jenkinsfile`, add a scheduled trigger:

```
// Scan will run everyday on master  
triggers { cron( '@daily' ) }
```

- Commit the change in this `deps-check` branch, in the context of the pull request
- The build will trigger automatically
- Navigate to `Jenkins` to see the results of the build
- The build should still succeed. In addition, it is also now scheduled for daily execution
- Everything looks good: merge the pull request

CONTINUE

pom.xml file

pom.xml file in master branch

[github.dxc.com/chrisswan/pet-clinic/blob/master/pom.xml](https://github.com/dxcchrisswan/pet-clinic/blob/master/pom.xml)

pom.xml file in deps-check branch

[github.dxc.com/chrisswan/pet-clinic/blob/deps-check/pom.xml](https://github.com/dxcchrisswan/pet-clinic/blob/deps-check/pom.xml)

Jenkinsfile

Jenkinsfile file

[github.dxc.com/chrisswan/pet-clinic/blob/deps-check/Jenkinsfile](https://github.com/dxcchrisswan/pet-clinic/blob/deps-check/Jenkinsfile)

Powered by KataCoda

**Badge!**



# GitHub used for support

 devops / yellow-belt

Unwatch 13

Star 5

Fork 28

<> Code

! Issues 25

Pull requests 0

Projects 1

Insights

Settings

Filters

is:issue is:open

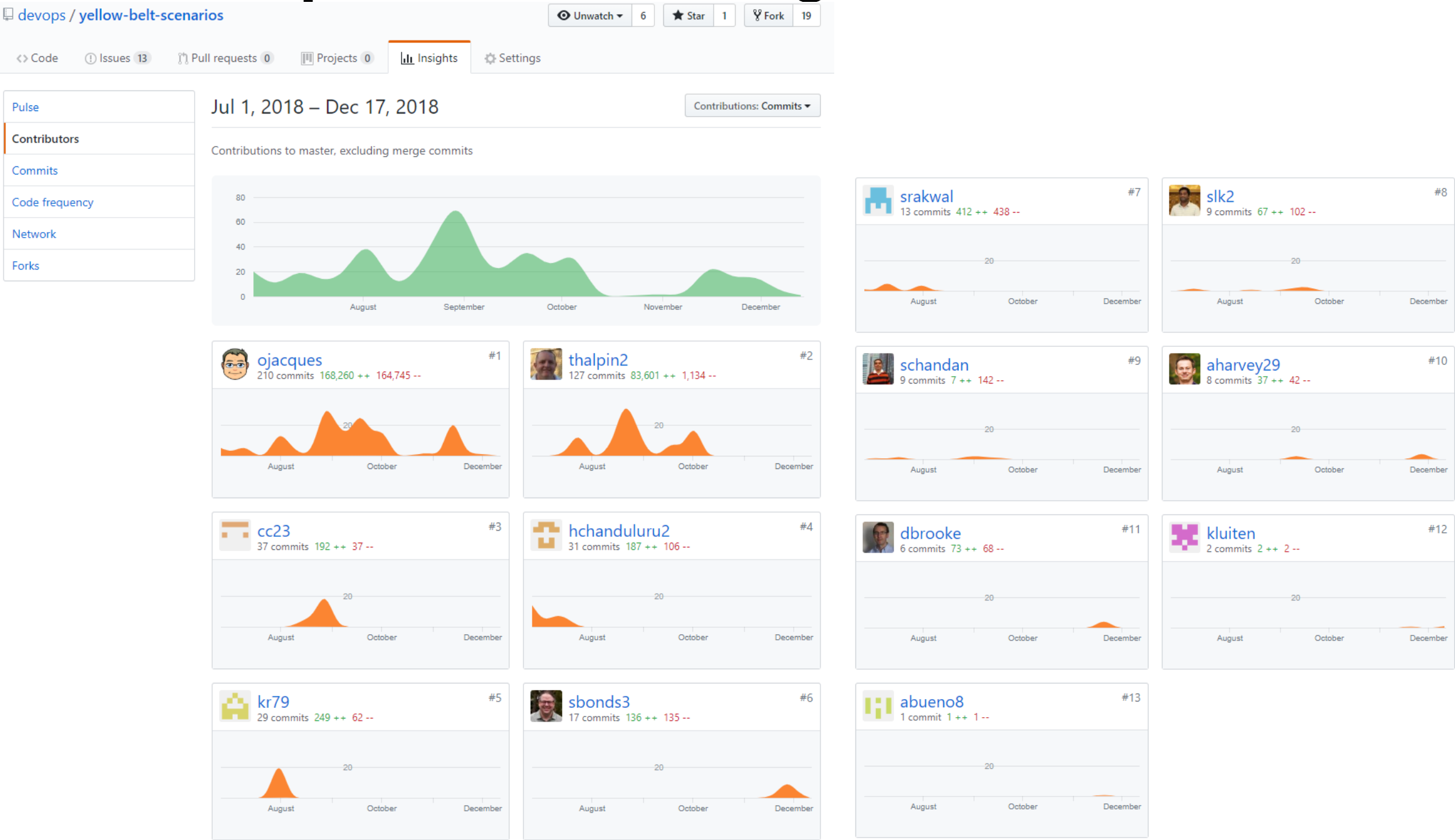
Labels

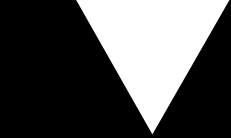
Milestones

New issue

| <input type="checkbox"/> | 25 Open ✓ 105 Closed                                                                                                                              | Author                                                                                | Labels | Projects | Milestones | Assignee | Sort |
|--------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|--------|----------|------------|----------|------|
| <input type="checkbox"/> | <b>Devops yellow belt WELCOME module : Stuck at step-3</b><br>#231 opened 25 minutes ago by tmounika2                                             |                                                                                       |        |          |            |          |      |
| <input type="checkbox"/> | <b>Yellow belt unable to log into jenkins</b><br>#230 opened 2 hours ago by jthomson21                                                            |                                                                                       |        |          |            |          |      |
| <input type="checkbox"/> | <b>Gethub issue</b> <b>? question</b><br>#229 opened 2 days ago by bfrichotiv 0 of 3                                                              |    |        |          |            | 1        |      |
| <input type="checkbox"/> | <b>Can't log on to Jenkins in the DevOps Dojo White Belt Katacoda Jenkins training</b><br>#228 opened 4 days ago by cgriiffith21                  |  |        |          |            |          |      |
| <input type="checkbox"/> | <b>DevOps Dojo - Yellow Belt</b><br>#227 opened 5 days ago by afincher3                                                                           |                                                                                       |        |          |            | 2        |      |
| <input type="checkbox"/> | <b>Column Resizing Uneven</b> <b>? question</b> wontfix<br>#224 opened 14 days ago by sbonds3                                                     |  |        |          |            | 2        |      |
| <input type="checkbox"/> | <b>Version Control ( in step 6 )</b> <b>student issue</b> Work in progress<br>#220 opened on Nov 14 by vrowthu                                    |  |        |          |            |          |      |
| <input type="checkbox"/> | <b>Jenkins pipeline execution Continuous Integration runs</b> <b>student issue</b> Update from user required<br>#219 opened on Nov 12 by tdermott |  |        |          |            | 6        |      |

# Students have polished the bugs out





# Time for Questions?